

Plantilla de Reporte Ejecutivo (tipo PowerPoint) – Programa de vulnerabilidades y SSVc

Estructura sugerida para presentar a Alta Dirección o Consejo los resultados de la encuesta, el IGM y las recomendaciones. [web:33][web:39][web:27][web:19][web:6]

Diapositiva 1 – Portada

- Título: “Estado de la gestión de vulnerabilidades y priorización basada en SSVc”
- Subtítulo: Organización, fecha, responsable.
- Nota al pie: Referencia a la encuesta interna y al marco SSVc.

Diapositiva 2 – Contexto y propósito

- Breve explicación del aumento de vulnerabilidades y limitaciones de enfoques puramente basados en CVSS. [web:35][web:38]
- Introducción a SSVc, KEV, Vulnrichment y EPSS como respuesta moderna al problema. [web:24][web:19][web:22][web:25][web:23][web:20]
- Objetivo de la presentación: mostrar situación actual, madurez (IGM), riesgos y plan de mejora.

Diapositiva 3 – Marco de referencia

- Esquema simplificado del árbol de decisión SSVc (explotación, impacto técnico, impacto en misión, exposición, automatización). [web:24][web:30][web:37]
- Menciona a NIS2 y expectativas de gestión de vulnerabilidades continua y basada en riesgo. [web:33][web:39][web:36]
- Posicionamiento de la organización frente a estas referencias (alto nivel).

Diapositiva 4 – Resultados globales de la encuesta

- Gráfico radar con IGM por bloques (gobernanza, inventario, detección, SSVc, métricas, NIS2, etc.).
- Comentario breve sobre fortalezas y debilidades destacadas. [web:27][web:32]

Diapositiva 5 – Análisis de gobernanza y cumplimiento

- Resumen de resultados en gobernanza (políticas, responsabilidades, reporting). [web:33][web:39]
- Resumen de preparación para NIS2 (procesos, evidencias, SLA, reporting). [web:33][web:36]
- Riesgos asociados a brechas en estos ámbitos (sanciones, reputación, continuidad).

Diapositiva 6 – Datos y capacidades técnicas

- Estado del inventario y correlación con CPE/CVE. [web:19][web:22][web:33]
- Nivel de adopción de KEV, Vulnrichment, EPSS y uso de datos de explotación real. [web:19][web:22][web:25][web:20][web:23]
- Grado de automatización (pipeline escáner – inteligencia – SSVc – ticketing). [web:8][web:18][web:28][web:17]

Diapositiva 7 – Métricas clave

- MTDD, MTTR, porcentaje de vulnerabilidades críticas remediadas en plazo, tamaño y tendencia del backlog. [web:32][web:27][web:35][web:41]
- Situación frente a benchmarks sectoriales si están disponibles.
- Indicador Global de Madurez (IGM) y nivel de madurez (Inicial/Básico/Gestionado/Optimizado).

Diapositiva 8 – Incidentes y eficacia de la priorización

- Datos básicos de incidentes recientes relacionados con vulnerabilidades. [web:27][web:35]
- Correlación (si existe) entre decisiones de priorización y origen de incidentes (ejemplos de falsos negativos). [web:16][web:20]
- Lecciones aprendidas y ajustes previstos en el modelo SSVC/EPSS.

Diapositiva 9 – ROI y caso de negocio

- Resumen de costes del programa de vulnerabilidades (herramientas, personal, proyectos). [web:27][web:32]
- Estimación de costes de incidentes evitados, multas potenciales (NIS2) y otros beneficios. [web:33][web:39][web:41]
- Cálculo simple de ROI y horizonte de recuperación de la inversión.

Diapositiva 10 – Hoja de ruta de 12-24 meses

- 3-5 iniciativas prioritarias (por ejemplo, adopción formal de un modelo SSVC, integración de KEV/Vulnrichment, automatización del pipeline, definición de SLA y reporting). [web:19][web:22][web:25][web:6][web:33]
- Secuencia temporal, dependencias, hitos clave.
- Recursos requeridos y riesgos de no actuar.

Diapositiva 11 – Conclusiones y decisiones solicitadas

- Resumen de la situación (“dónde estamos”, “dónde queremos estar”).
- Decisiones concretas que se solicitan a la Alta Dirección (aprobación de plan, presupuesto, cambios de gobernanza). [web:33][web:39]
- Cierre con mensaje claro: priorizar vulnerabilidades de forma inteligente no es opcional; la única duda es cuánto tardaremos en hacerlo bien.

Esta estructura puede adaptarse a entornos más técnicos (añadiendo detalles de arquitectura) o a entornos más regulatorios (añadiendo mapeos específicos a normativas sectoriales).